BrickStore · Documentación del proyecto

1. Funcionamiento general del sistema

BrickStore es un sistema web para una tienda de bloques de construcción que permite gestionar las cuentas de sus usuarios. Existen dos roles: **cliente** y **admin** (empleado de la tienda).

- Cualquier persona puede **crear una cuenta** desde registro.php. El sistema valida los datos, comprueba que el DNI y el correo no estén repetidos y guarda el usuario en la tabla usuarios con la contraseña cifrada mediante hash. Los registros públicos siempre tienen rol cliente.
- Desde login.php el usuario **inicia sesión** con su correo y contraseña. PHP busca el correo en la base de datos y compara la contraseña con password_verify(). Si es correcta, guarda su id, nombre y rol en $_SESSION.
- El cliente entra a su **panel personal** (panel.php), donde ve sus datos. Esa página solo se puede ver con la sesión iniciada.
- El administrador entra al **panel administrativo** (admin_usuarios.php), donde puede registrar usuarios, ver el listado de usuarios activos, buscarlos por nombre, apellido, DNI o correo, editarlos y archivarlos.
- **Archivar** no borra al usuario: se guarda la fecha en fecha_archivado. Un usuario archivado no aparece en el listado de activos y no puede iniciar sesión. Desde usuarios_archivados.php el admin puede **reactivarlo** (vuelve fecha_archivado a NULL).
- cerrar_sesion.php borra la sesión y la cookie, y vuelve al login.

La tienda (agregado extra)

Además de lo que pide la consigna, BrickStore funciona como tienda:

- La **página de inicio** (index.php) muestra un catálogo de 6 sets reales de LEGO. Los datos (nombre, número de set, precio en dólares, piezas y edad) se tomaron de la tienda oficial de LEGO de Estados Unidos; las descripciones están escritas para este proyecto y las fotos son de Wikimedia Commons y Unsplash, con licencias libres (los autores están en el README.md).
- El catálogo está en un solo archivo, includes/funciones.php, como un array de PHP. No está en la base de datos porque la consigna pide administrar usuarios, no productos.
- Cada producto tiene su **página** (producto.php?id=75192) con foto, descripción, datos y un selector de cantidad.
- El **carrito** (carrito.php) se guarda en la sesión ($_SESSION['carrito']), así se puede armar sin tener cuenta. Permite agregar, cambiar cantidades y quitar productos.
- **Finalizar compra** exige iniciar sesión. Si el usuario no inició sesión, va al login y después vuelve al carrito con sus productos. Al confirmar, el pedido se guarda en las tablas pedidos y pedido_items, el carrito se vacía y el pedido aparece en **Mis pedidos**, dentro del panel personal.

2. Medidas de seguridad implementadas

Medida	Qué protege	Dónde está
password_hash() al guardar y password_verify() al comprobar	Las contraseñas nunca se guardan como texto plano: si alguien ve la base de datos, no puede leerlas	includes/funciones.php (insertarUsuario), editar_usuario.php, login.php
Consultas preparadas con PDO (prepare + execute con ?) en todas las consultas	Inyección SQL: los datos del usuario nunca se mezclan con el código SQL	Todos los archivos que consultan la base
PDO::ATTR_EMULATE_PREPARES => false	Las consultas se preparan realmente en MySQL	conexion.php
Mensaje genérico si falla la conexión o una consulta (el detalle va a error_log)	No se exponen datos internos del servidor	conexion.php, includes/funciones.php, editar_usuario.php
requerirLogin() al inicio de cada página privada	Nadie entra al panel sin iniciar sesión	includes/funciones.php, usado en panel.php y en las páginas admin
requerirAdmin() en todas las páginas y acciones administrativas (también en archivar y reactivar)	Un cliente no puede usar funciones de administrador, ni escribiendo la URL a mano	includes/funciones.php + todos los archivos admin
En cada página privada se vuelve a consultar el usuario en la base	Si un admin archiva a alguien con la sesión abierta, esa sesión se corta	requerirLogin() en includes/funciones.php
session_regenerate_id(true) al iniciar sesión	Fijación de sesión (alguien que conocía un ID de sesión viejo no lo puede reutilizar)	login.php
Cookie de sesión httponly y samesite=Lax	JavaScript no puede leer la cookie y no se envía desde otros sitios en formularios POST	includes/funciones.php
Escape con htmlspecialchars() (función e()) en todo lo que se muestra	Inyección de código HTML/JavaScript (XSS), incluido el texto del buscador	Todas las vistas
Token CSRF en todos los formularios, verificado con hash_equals()	Solicitudes no autorizadas: que otra página haga que el admin edite, archive o	includes/funciones.php (tokenCsrf, campoCsrf, verificarCsrf)

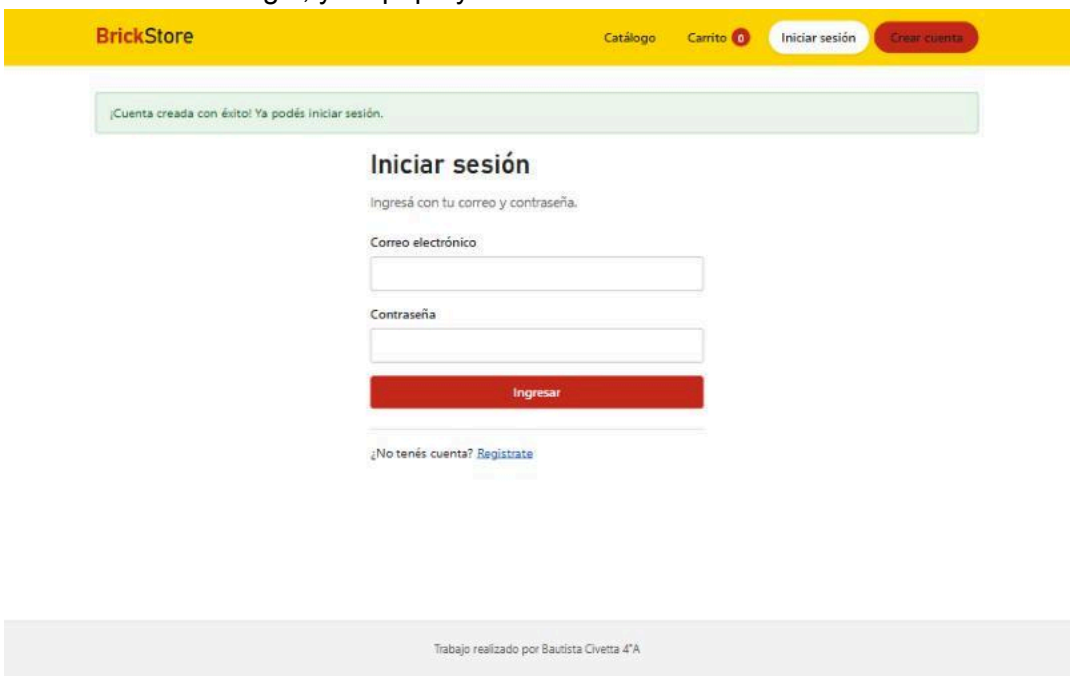
Medida	Qué protege	Dónde está
	reactive sin querer	
Archivar y reactivar solo por POST	No se puede archivar a alguien con un simple enlace	archivar_usuario.php, reactivar_usuario.php
Validación del ID (entero positivo y existente)	Datos manipulados en la URL o el formulario	validarId() en includes/funciones.php, editar_usuario.php
Validación de todos los campos en el servidor	Datos vacíos, con formato incorrecto o repetidos, aunque se saltee la validación del navegador	includes/funciones.php
UNIQUE en dni y email + control en PHP	DNI y correo nunca repetidos	tienda_legos.sql, includes/funciones.php
El rol del registro público se fija en el servidor	Nadie puede registrarse como admin modificando el formulario	registro.php
Las consultas que muestran usuarios nunca seleccionan la columna password	Ninguna pantalla muestra contraseñas ni hashes	Todas las vistas
Mensaje genérico de login ("correo o contraseña incorrectos")	No se revela si un correo está registrado	login.php
Un admin no puede archivarse ni quitarse su propio rol	Que el sistema se quede sin administrador por error	archivar_usuario.php, editar_usuario.php
Tienda: los precios del pedido se toman del catálogo del servidor	Nadie puede comprar más barato cambiando el precio desde el navegador, porque el formulario solo manda el número de set y la cantidad	carrito.php
Tienda: el producto y la cantidad se validan (que exista, entre 1 y 10)	Datos inventados o manipulados en el formulario o en la URL	carrito.php, producto.php
Tienda: token CSRF y POST en agregar, actualizar, quitar y finalizar	Que otra página agregue productos o finalice una compra sin que el usuario lo sepa	carrito.php
Tienda: finalizar compra	Que se registren pedidos sin	carrito.php (requerirLogin())

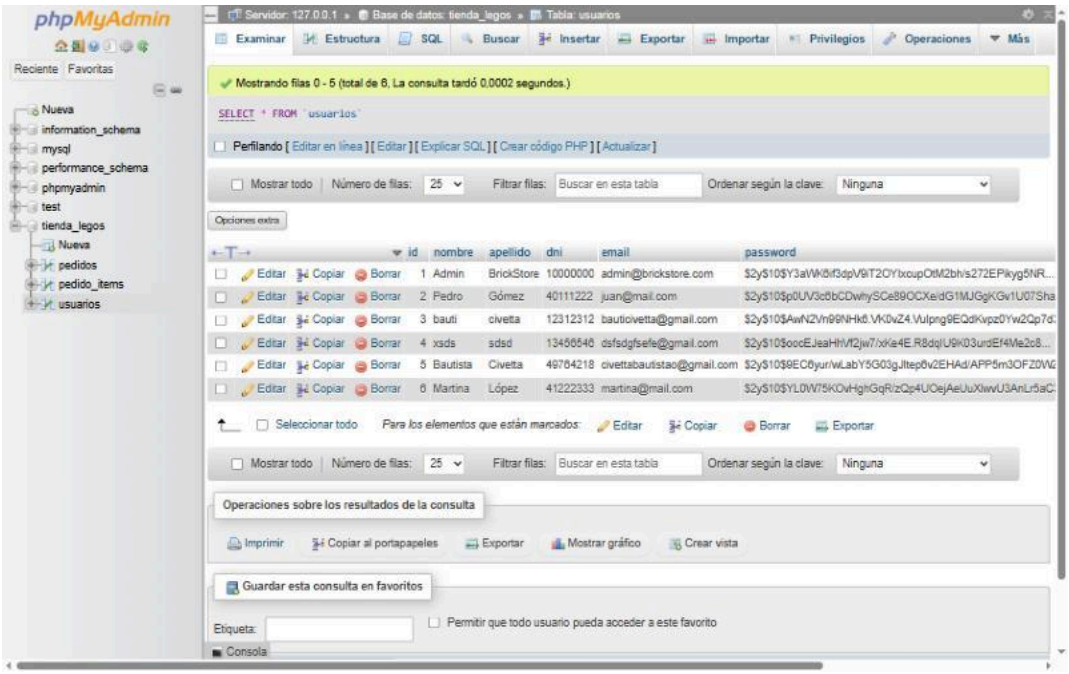
Medida	Qué protege	Dónde está
exige sesión activa	un usuario detrás	
Tienda: transacción al guardar el pedido	Si falla algo a mitad de camino, no queda un pedido incompleto: se guardan el pedido y todos sus productos, o nada	carrito.php (beginTransaction, commit, rollBack)
Tienda: cada usuario ve solo sus pedidos	Que un cliente vea las compras de otro	panel.php (WHERE p.usuario_id = ?)

3. Guía de las 9 pruebas obligatorias (y qué capturar)

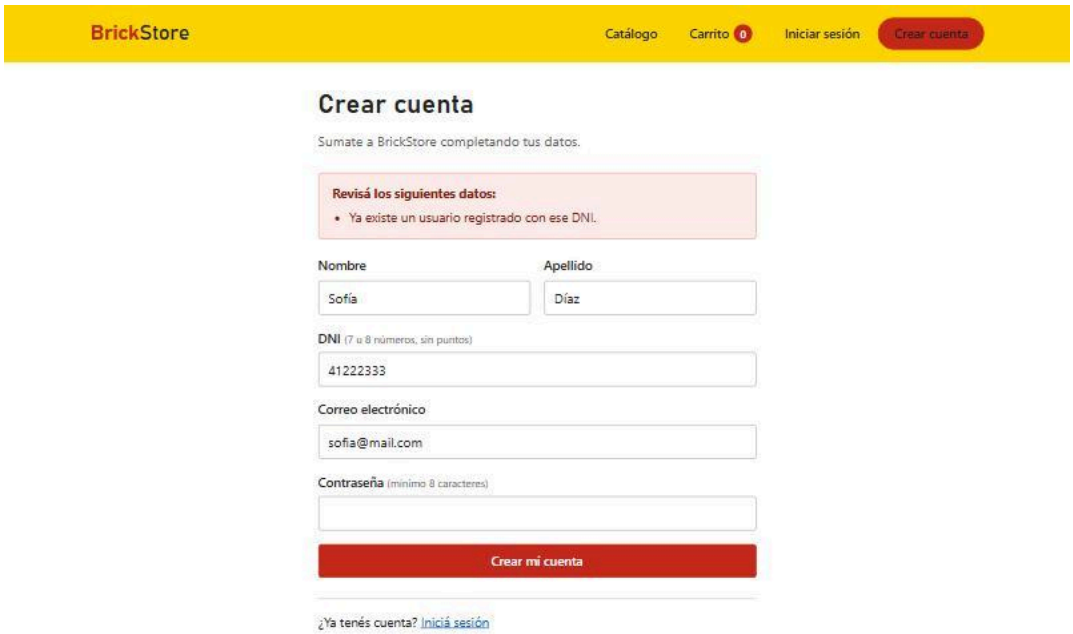
Antes de empezar, importá tienda_legos.sql y abrí http://localhost/tienda_legos/.

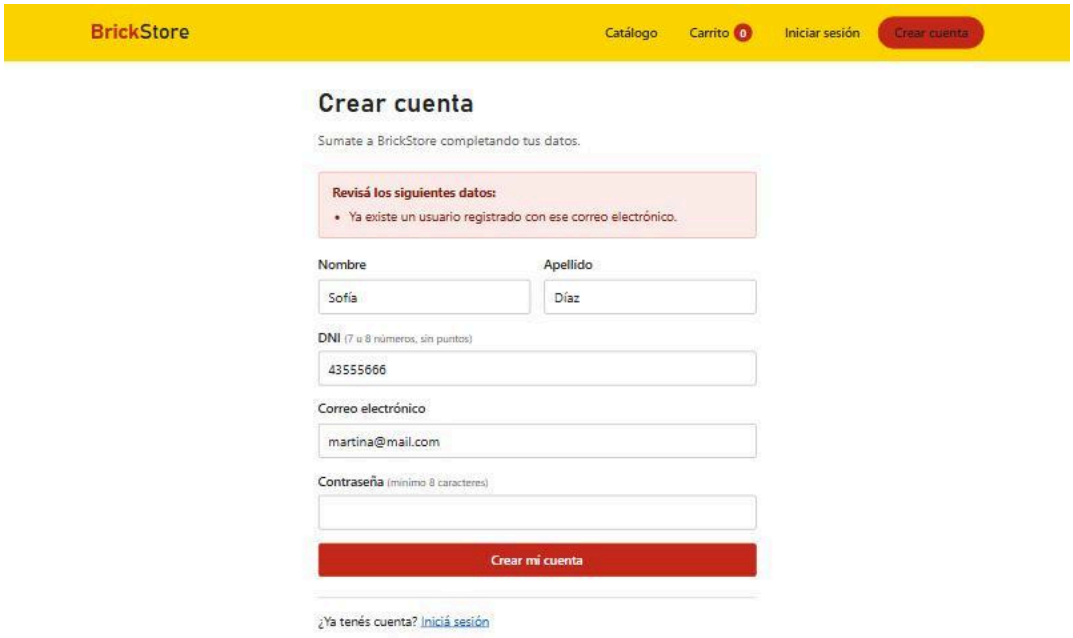
1. **Registro correcto.** Ir a *Crear cuenta*, completar Juan / Gómez / 40111222 / juan@mail.com / clave1234 y enviar. **Captura:** El mensaje verde "¡Cuenta creada con éxito!" en el login, y en phpMyAdmin la fila nueva con la contraseña como hash $2y$....



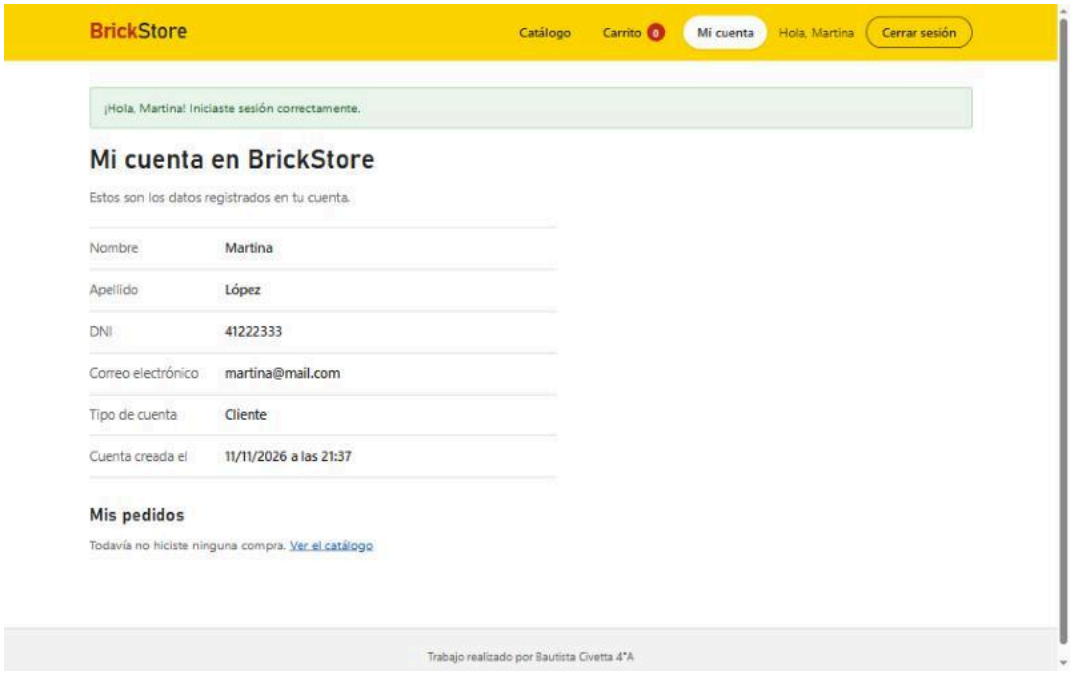


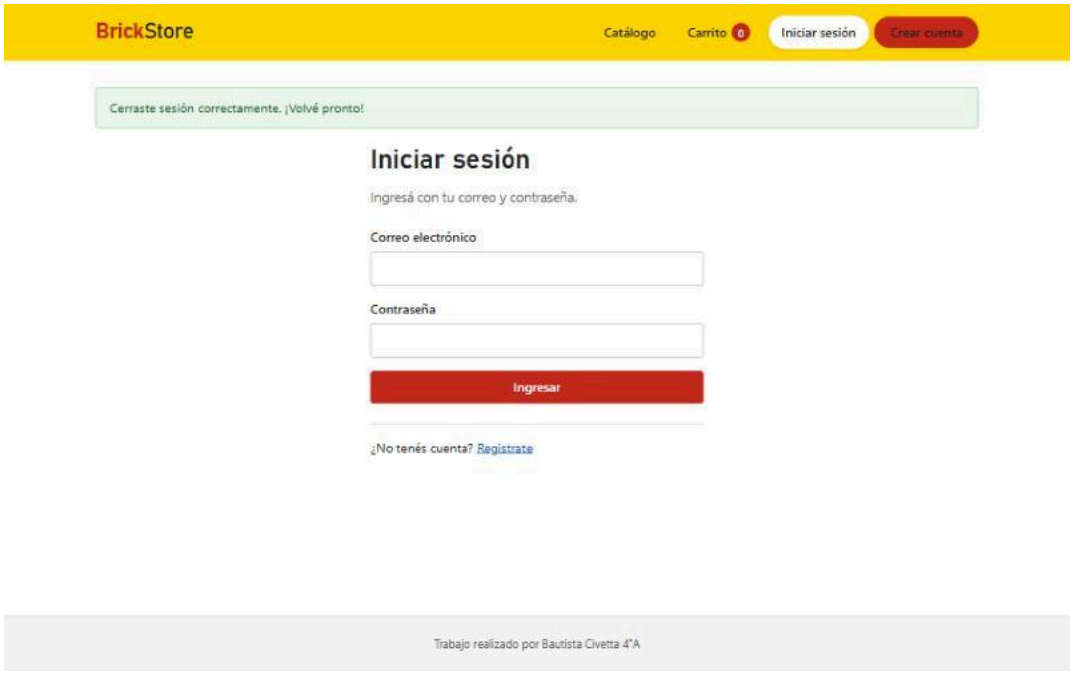
2. **Duplicados.** Registrarse de nuevo con el DNI 40111222 y otro correo; después con otro DNI y juan@mail.com. **Captura:** Los mensajes rojos "Ya existe un usuario registrado con ese DNI" y "...con ese correo electrónico".



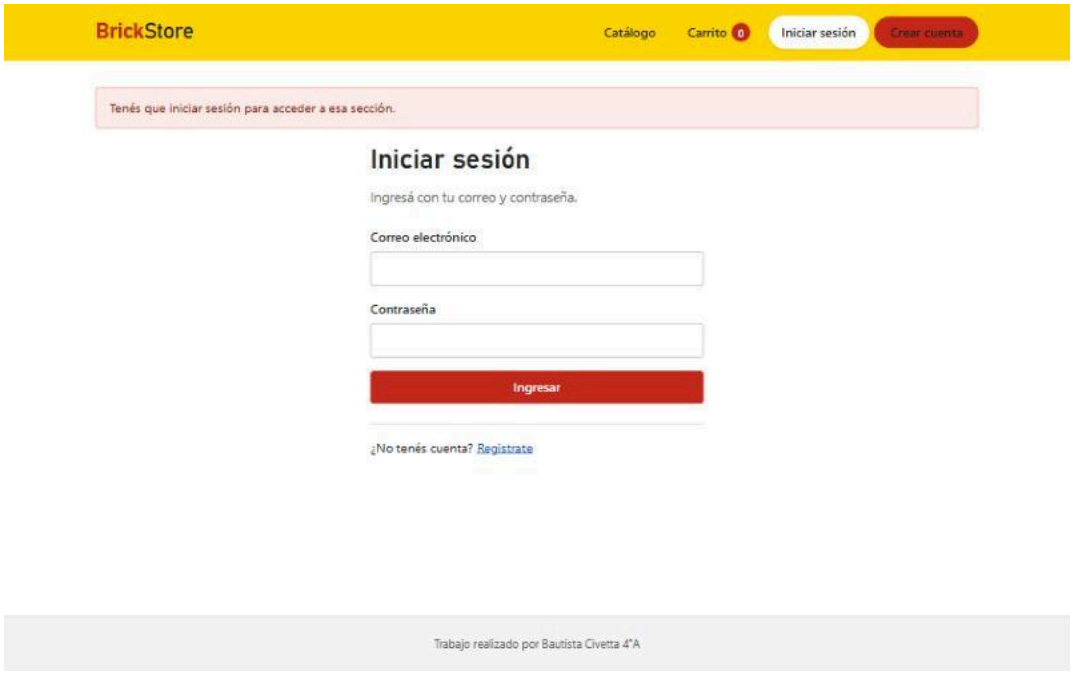


3. **Iniciar y cerrar sesión.** Ingresar con juan@mail.com / clave1234, y luego tocar *Cerrar sesión*. **Captura:** El panel con "Hola, Juan" en el menú, y el mensaje "Cerraste sesión correctamente".

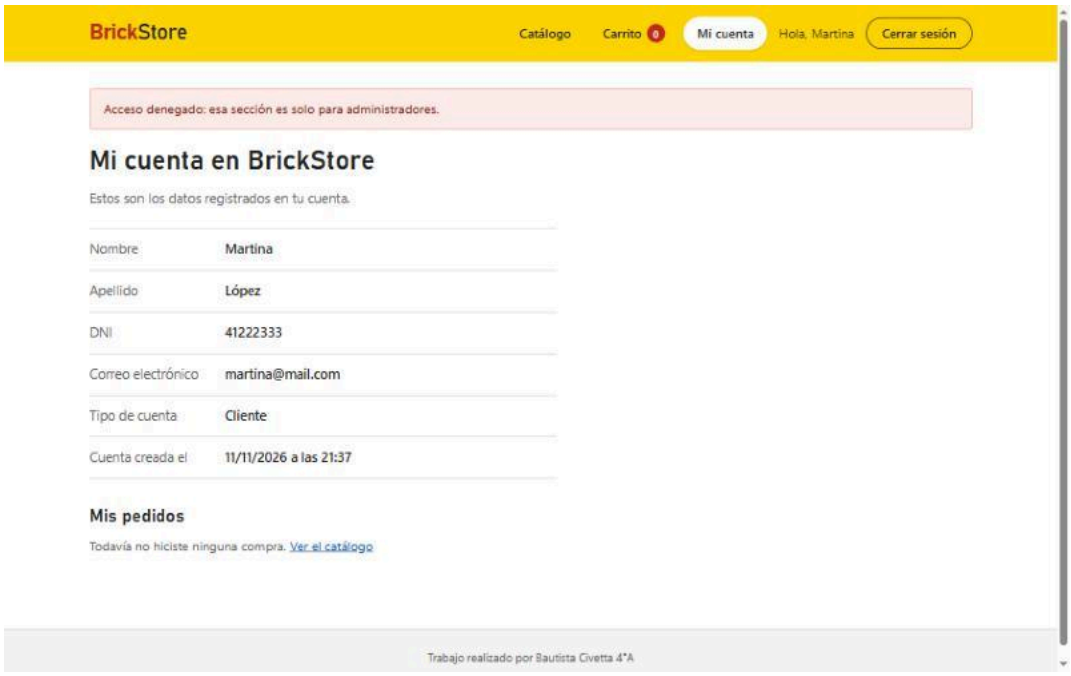




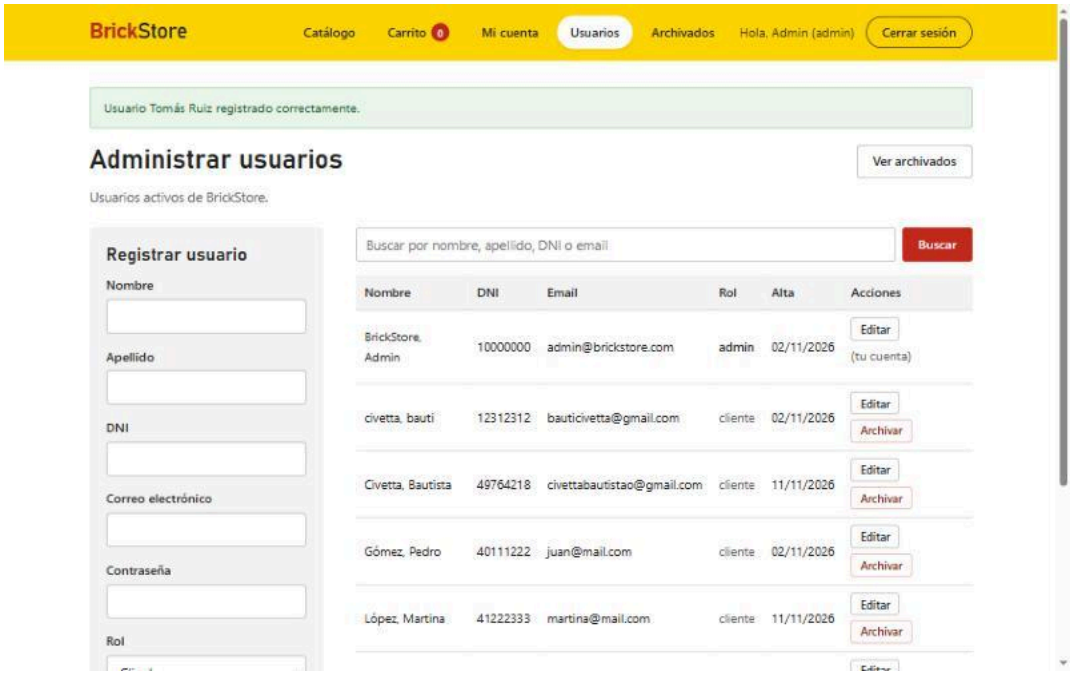
4. **Panel sin autenticarse.** Sin sesión, escribir en la barra http://localhost/tienda_legos/panel.php. **Captura:** La redirección al login con "Tenés que iniciar sesión para acceder a esa sección".

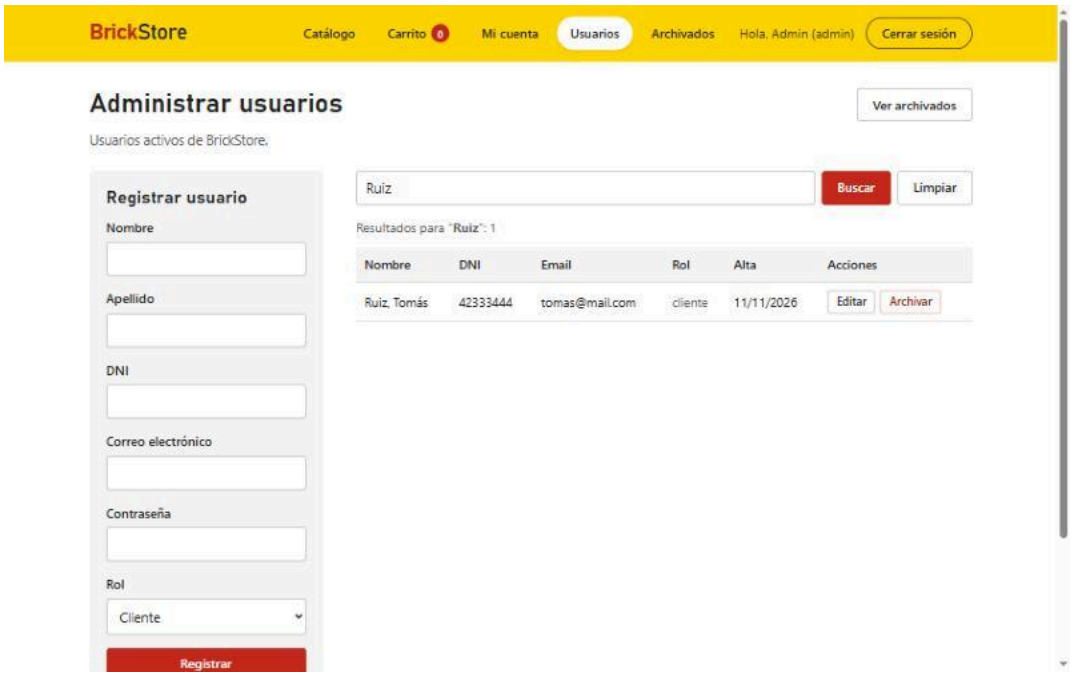


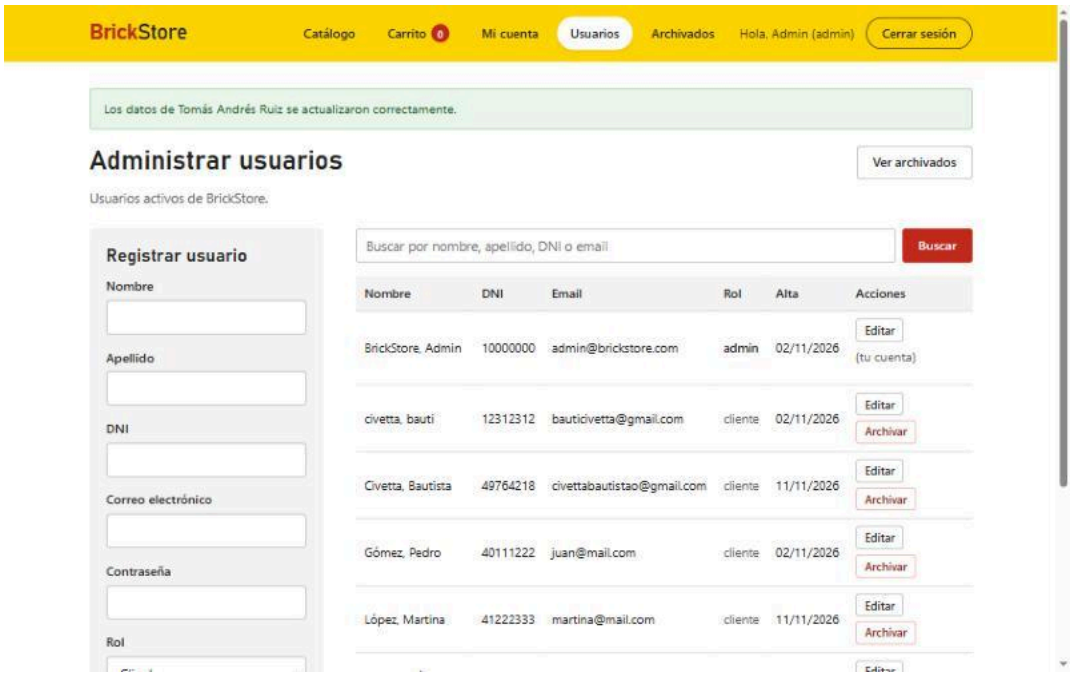
5. **Un cliente no accede a lo administrativo.** Con la sesión de Juan, escribir .../admin_usuarios.php. **Captura:** El mensaje "Acceso denegado: esa sección es solo para administradores" y el menú sin las opciones de admin.



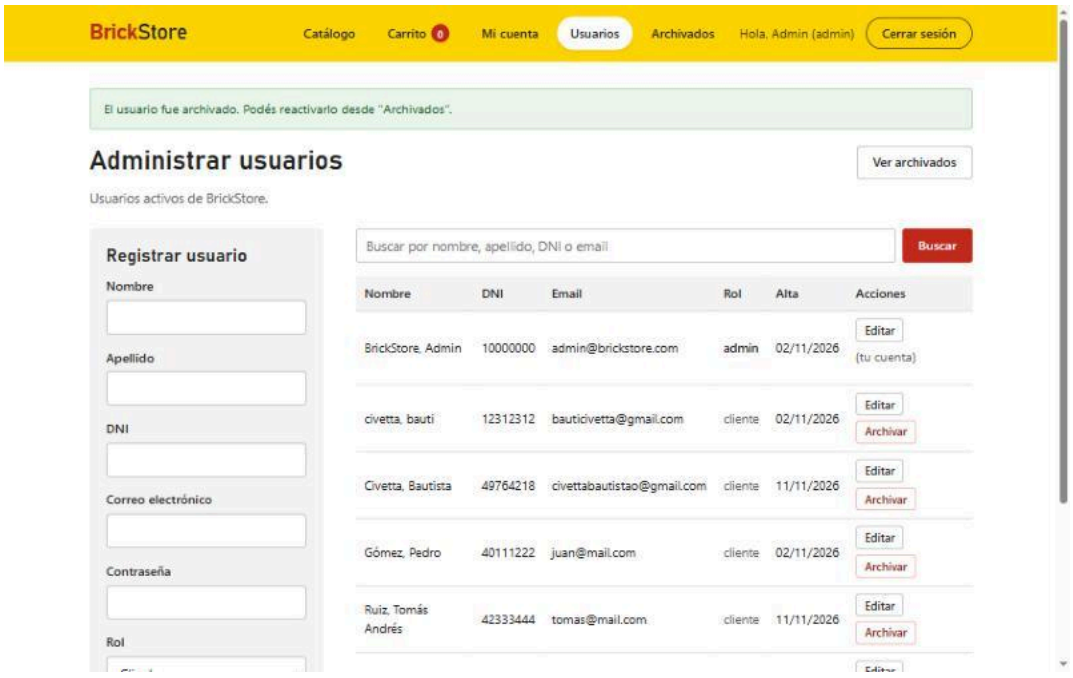
6. **El admin registra, busca y edita.** Ingresar con admin@brickstore.com / Admin1234. Registrar a otro usuario desde el formulario de la izquierda; buscar "Gómez" o "40111"; tocar *Editar* y cambiar el nombre. **Captura:** El usuario nuevo en la tabla, el resultado de la búsqueda y el mensaje "Los datos ... se actualizaron correctamente".

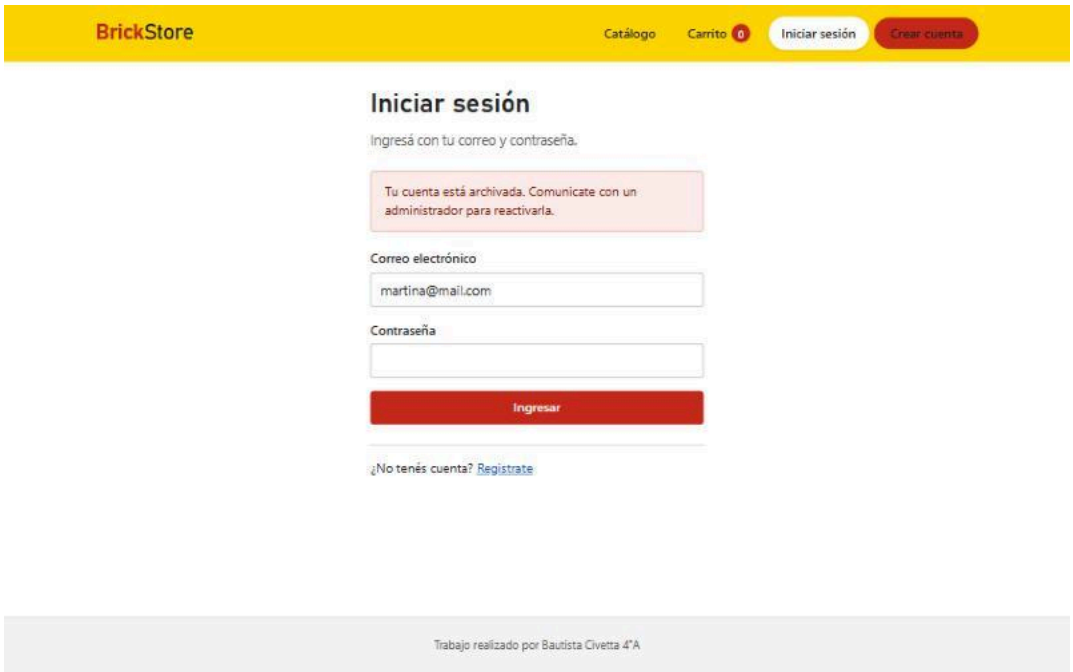




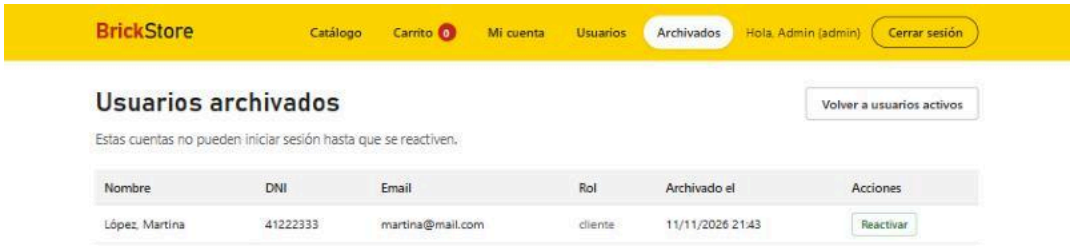


7. **Los archivados desaparecen de activos.** Tocar *Archivar* en Juan y confirmar. **Captura:** El mensaje "El usuario fue archivado" y la tabla sin Juan. Opcional: intentar ingresar como Juan ("Tu cuenta está archivada").

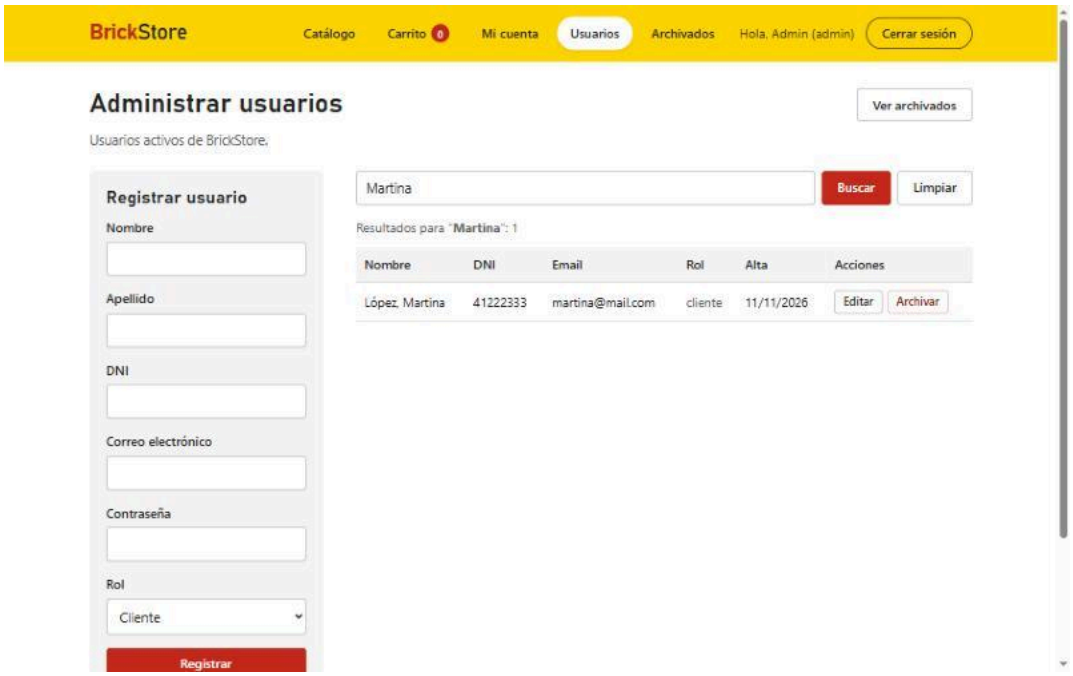




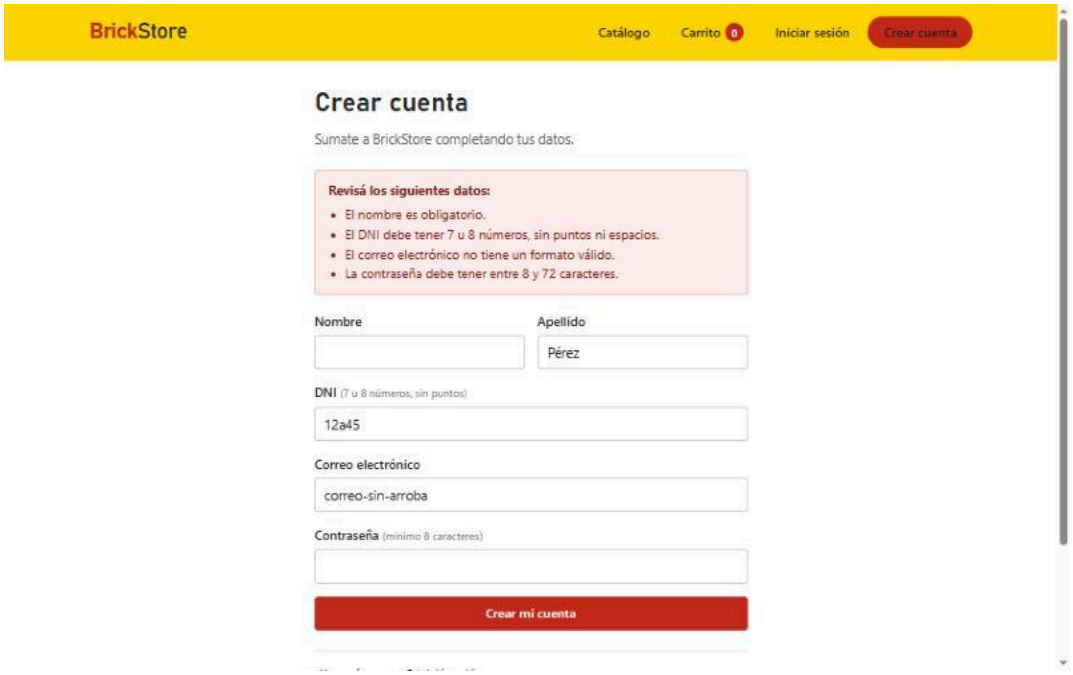
8. **Consultar y reactivar archivados.** Ir a *Archivados* y tocar *Reactivar*. **Captura:** Juan en la lista de archivados con su fecha, el mensaje "El usuario fue reactivado" y Juan de nuevo en activos.

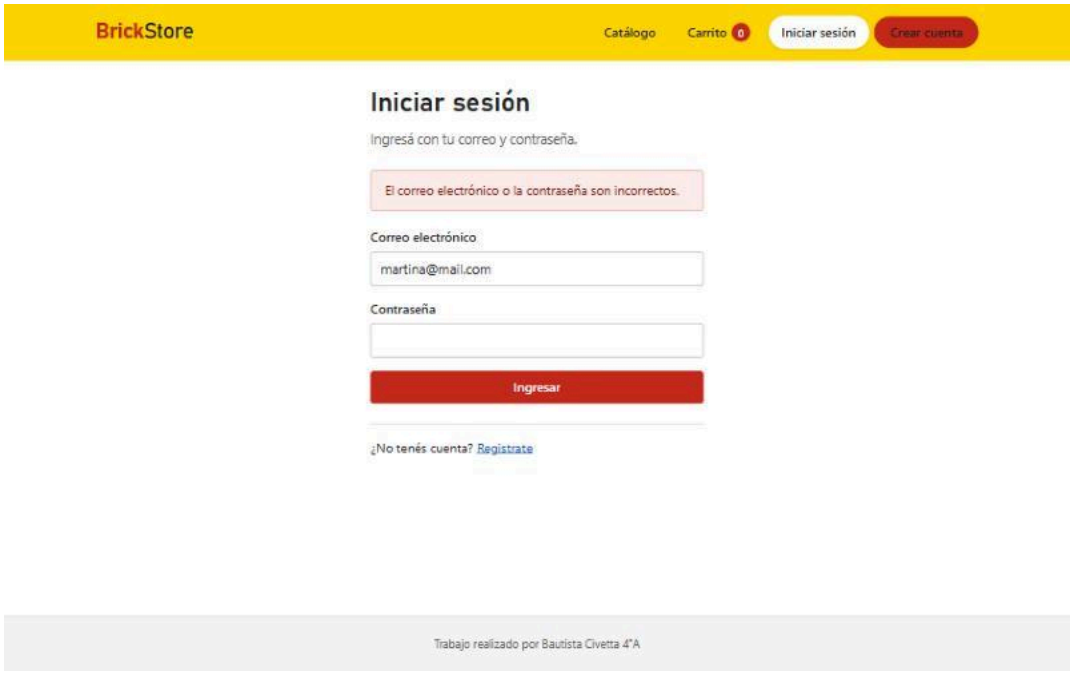

BrickStore
Catálogo
Carrito 0
Mi cuenta
Usuarios
Archivados
Hola, Admin (admin)
Cerrar sesión
Usuarios archivados
Volver a usuarios activos
Estas cuentas no pueden iniciar sesión hasta que se reactiven.
Nombre
DNI
Email
Rol
Archivado el
Acciones
López, Martina
41222333
martina@mail.com
cliente
11/11/2026 21:43
Reactivar


BrickStore
Catálogo
Carrito 0
Mi cuenta
Usuarios
Archivados
Hola, Admin (admin)
Cerrar sesión
El usuario fue reactivado y ya puede iniciar sesión.
Usuarios archivados
Volver a usuarios activos
Estas cuentas no pueden iniciar sesión hasta que se reactiven.
No hay usuarios archivados.



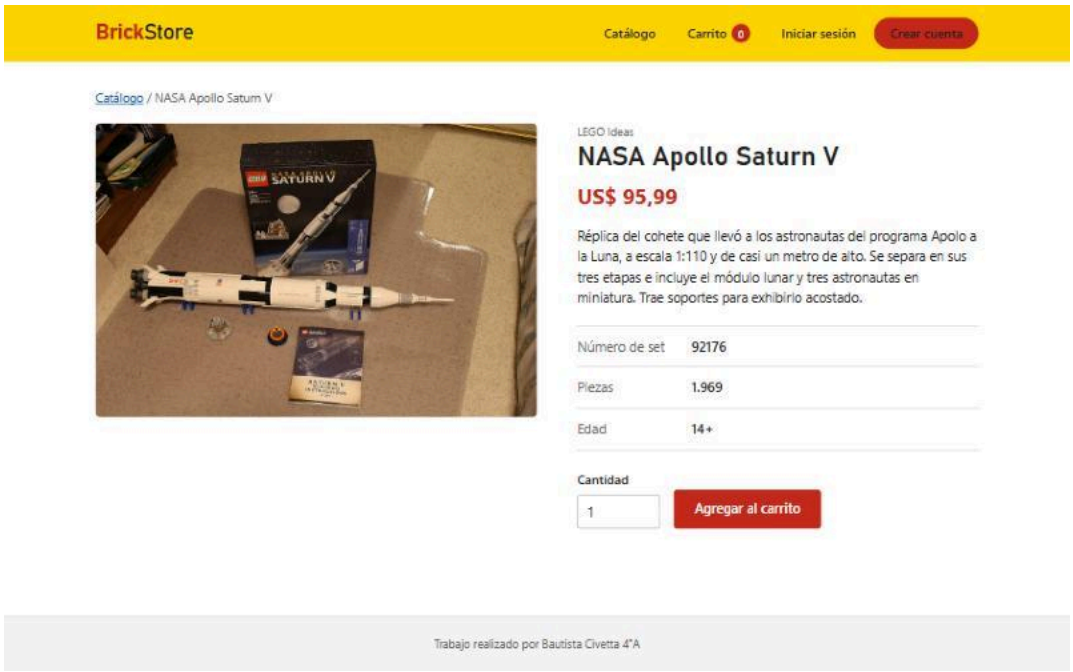
9. **Mensajes comprensibles.** Enviar el registro vacío o con un DNI con letras; intentar ingresar con una contraseña incorrecta. **Captura:** La lista de errores ("El nombre es obligatorio", "El DNI debe tener 7 u 8 números...") y "El correo electrónico o la contraseña son incorrectos".



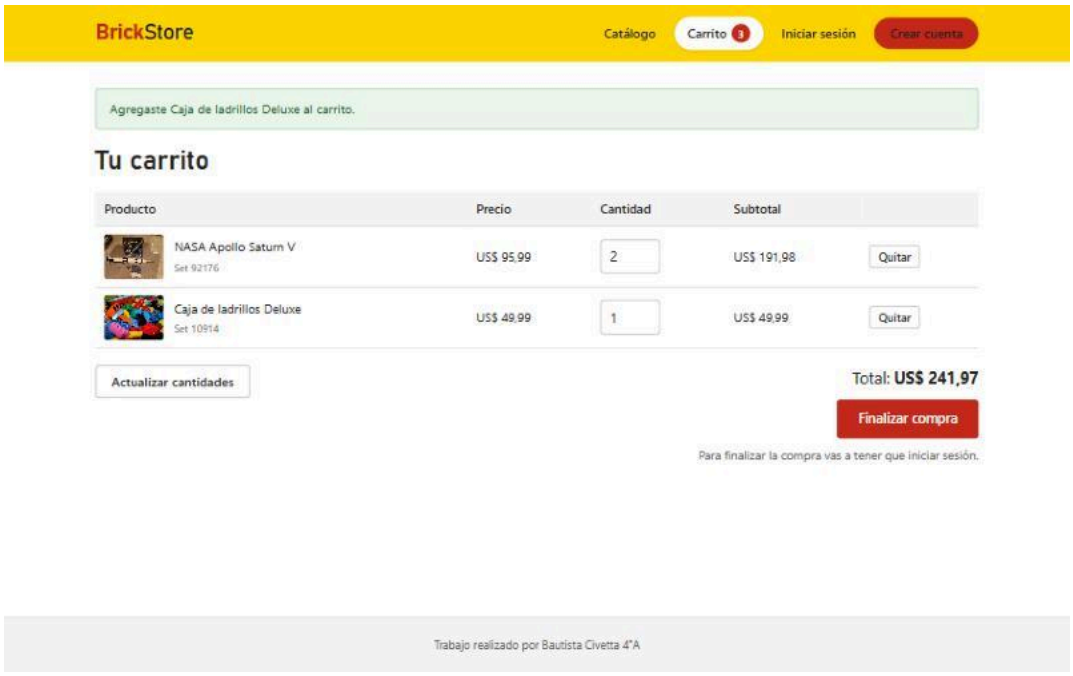


Pruebas de la tienda (extra, no las pide la consigna)

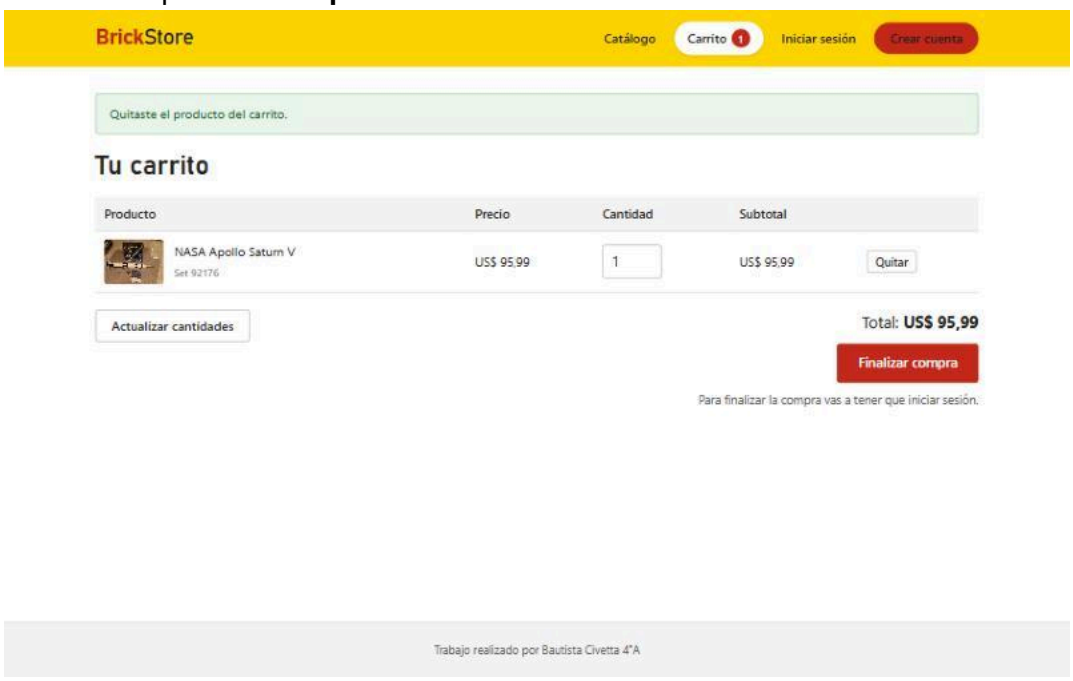
10. **Ver un producto.** En el inicio, tocar la foto o el nombre de un set. **Captura:** La página del producto con foto, precio, descripción, número de set, piezas y edad.



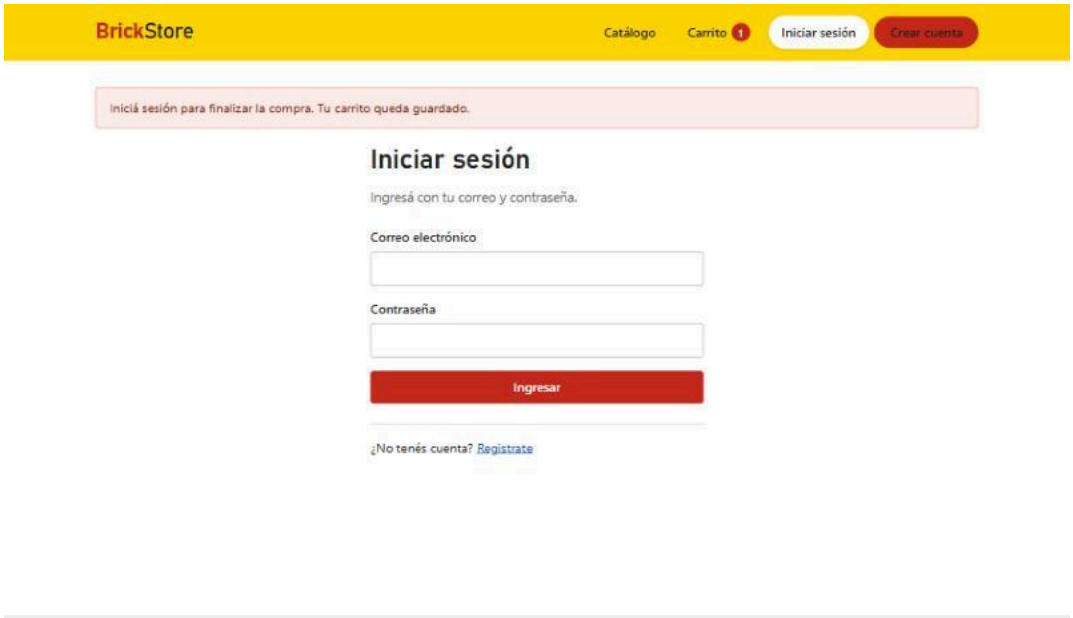
11. **Agregar al carrito.** Tocar *Agregar al carrito* en dos productos distintos; en uno, elegir cantidad 2. **Captura:** El carrito con los dos productos, los subtotales, el total y el número 3 en el círculo rojo del carrito, en el menú.



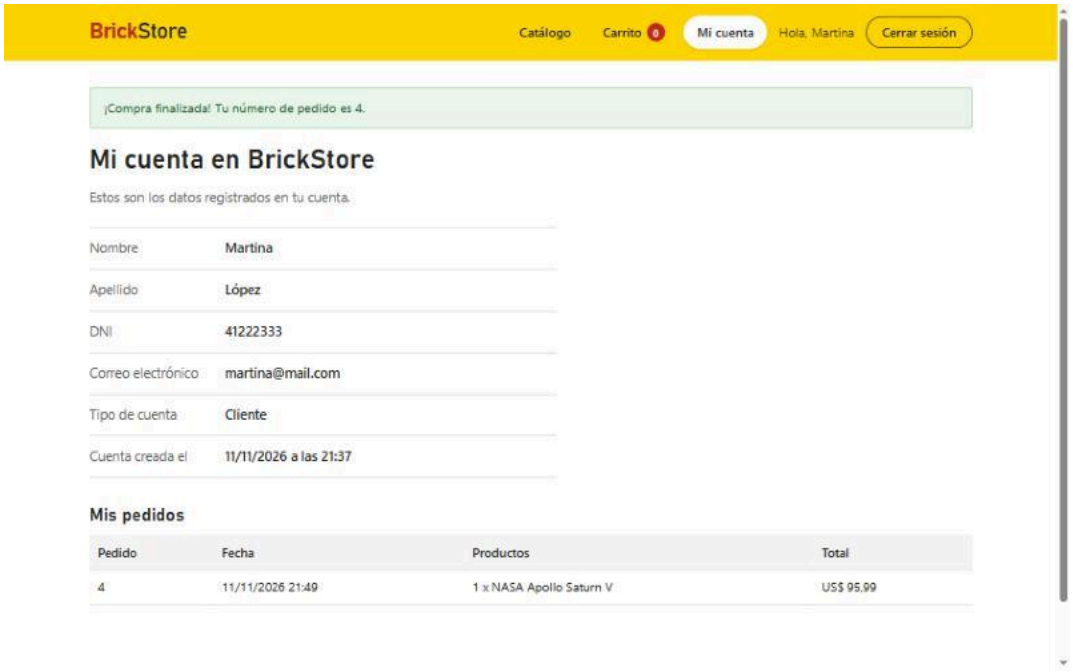
12. **Cambiar y quitar.** Cambiar una cantidad, tocar *Actualizar cantidades* y después *Quitar* en un producto. **Captura:** El total recalculado.

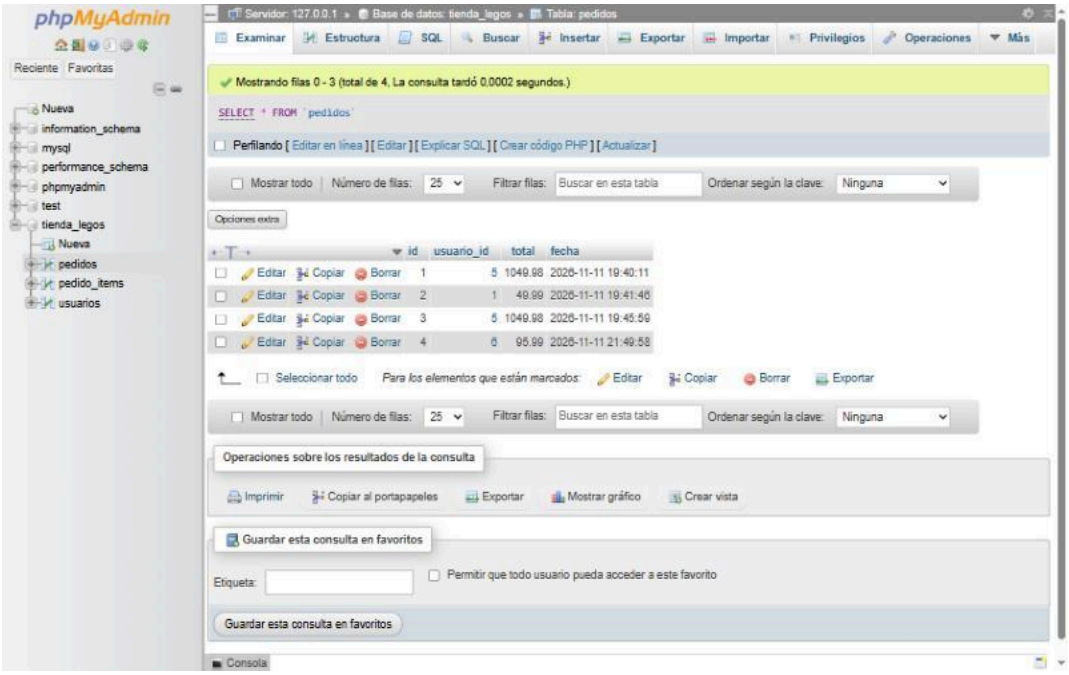


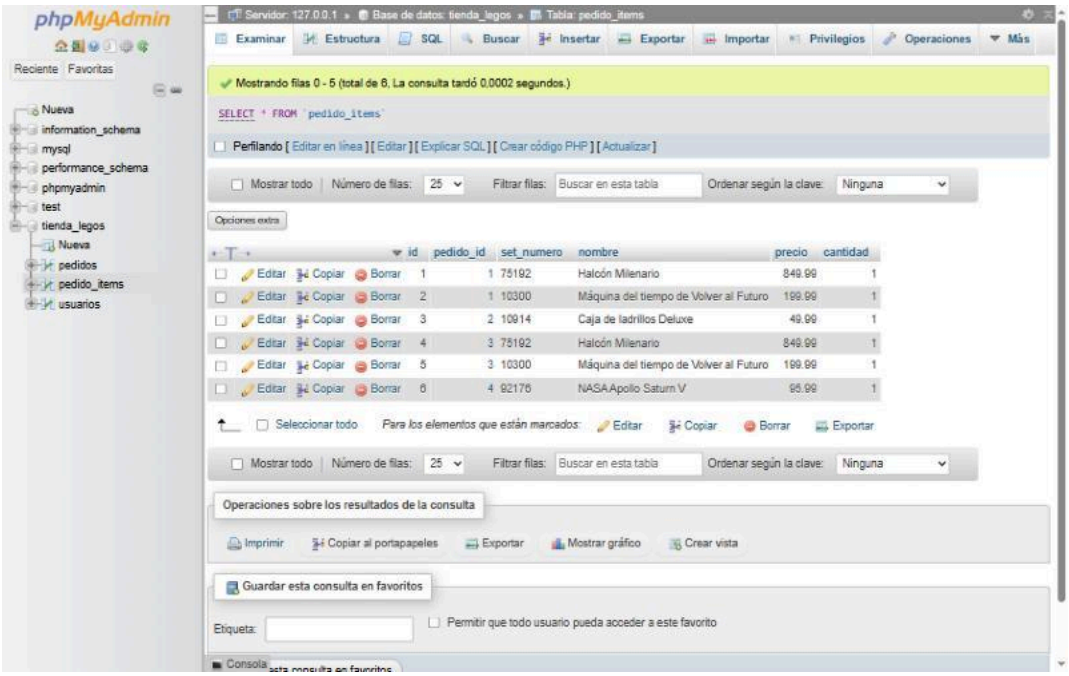
13. **Finalizar sin sesión.** Con la sesión cerrada, tocar *Finalizar compra*. **Captura:** El login con el mensaje "Iniciá sesión para finalizar la compra. Tu carrito queda guardado." Al iniciar sesión, vuelve al carrito con los productos.



14. **Finalizar compra.** Con la sesión iniciada, tocar *Finalizar compra*. **Captura:** El panel con "¡Compra finalizada! Tu número de pedido es ..." y el pedido en *Mis pedidos*. En phpMyAdmin, la fila en pedidos y sus productos en pedido_items.







4. Dificultades encontradas y cómo fueron resueltas

Completá esta sección con lo que te pase a vos. Abajo hay errores comunes y su solución como referencia; anotá cuáles te aparecieron, cómo te diste cuenta y qué hiciste.

Error común	Causa	Solución
Cannot modify header	Se imprimió algo (un espacio,	Hacer toda la lógica y las

Error común	Causa	Solución
information - headers already sent	un echo, un error) antes de header() o session_start()	redirecciones antes de mostrar HTML; no dejar espacios antes de <?php
"No se pudo conectar con la base de datos"	MySQL apagado, base no importada o contraseña de root distinta	Encender MySQL en XAMPP/Laragon, importar el .sql, revisar $clave en conexion.php
SQLSTATE[42S02]: Base table or view not found	La tabla tiene otro nombre o no se creó	Volver a importar tienda_legos.sql
El login falla aunque la contraseña es correcta	La columna password es demasiado corta y el hash se cortó, o se guardó la contraseña sin hashear	password VARCHAR(255) y guardar siempre con password_hash()
SQLSTATE[23000]: Integrity constraint violation: Duplicate entry	Se intentó insertar un DNI o email repetido	Validar duplicados en PHP antes del INSERT y mostrar un mensaje claro
Los acentos se ven como Ã©	Distinto charset entre PHP, MySQL y HTML	utf8mb4 en la base y en el DSN, y <meta charset="UTF-8">
La sesión "se pierde" al cambiar de página	Falta session_start() en alguna página	Incluir includes/funciones.php, que inicia la sesión, en todas las páginas
El mensaje de "Cerraste sesión" no aparecía	Después de session_destroy() PHP reutilizaba el ID de sesión que se acababa de borrar	Llamar a session_regenerate_id(true) después del nuevo session_start()
Después de cambiar el CSS, la página se seguía viendo con el diseño viejo	El navegador guarda una copia del archivo CSS y no lo vuelve a pedir	Agregar ?v= con la fecha de modificación del archivo (filemtime) al enlace del CSS en includes/plantilla.php: cuando el archivo cambia, cambia la dirección y el navegador lo descarga de nuevo

5. Cómo se conectan los formularios, PHP, las sesiones y la base de datos

Recorrido de un dato, por ejemplo el registro de un cliente:

1. **Formulario HTML** (registro.php): el usuario escribe sus datos. El <form method="post"> los envía al servidor. También viaja un campo oculto con el **token CSRF**.
2. **PHP recibe los datos** en el array $_POST. obtenerDatosUsuario() toma solo los campos esperados y les quita los espacios.
3. **Validación**: validarUsuario() revisa campos vacíos y formatos, y hace un SELECT con PDO para saber si el DNI o el correo ya existen. Si hay errores, se vuelve a mostrar el formulario con los mensajes y los datos cargados.
4. **Base de datos**: si todo está bien, insertarUsuario() cifra la contraseña con password_hash() y ejecuta un INSERT preparado. MySQL guarda la fila y completa sola id y fecha_creacion.
5. **Login y sesión**: en login.php, PHP busca el correo con un SELECT preparado y compara la contraseña con password_verify(). Si coincide, guarda usuario_id, nombre y rol en $_SESSION. PHP le da al navegador una cookie con el ID de sesión, y en cada página siguiente esa cookie le permite a PHP saber quién es.
6. **Consulta**: panel.php llama a requerirLogin(), toma $_SESSION['usuario_id'] y hace un SELECT para mostrar los datos, escapados con htmlspecialchars().
7. **Administración**: en las páginas admin, requerirAdmin() revisa que rol sea "admin". Buscar es un SELECT ... LIKE, editar es un UPDATE, archivar es UPDATE ... SET fecha_archivado = NOW() y reactivar es UPDATE ... SET fecha_archivado = NULL. Nunca se usa DELETE.
8. **Compra (extra)**: el botón *Agregar al carrito* envía por POST el número de set. carrito.php lo valida y lo guarda en $_SESSION['carrito']. Al *Finalizar compra*, PHP calcula el total con los precios del catálogo y, dentro de una transacción, hace un INSERT en pedidos y uno por producto en pedido_items. panel.php los lee con un SELECT ... JOIN y los muestra en *Mis pedidos*.

6. Tabla de verificación de la consigna

Punto de la consigna	Cómo se cumple	Archivo
A Crear cuenta desde un formulario	Formulario público de registro	registro.php
A Nombre, apellido, DNI, correo y contraseña	Los cinco campos del formulario	registro.php
A Validar campos obligatorios	required en HTML + validación en el servidor	includes/funciones.php
A Evitar DNI y correo duplicados	SELECT previo + UNIQUE en la tabla	includes/funciones.php, tienda_legos.sql
A Guardar en la base de datos	INSERT preparado	includes/funciones.php
B Acceso con correo y contraseña	Formulario de login	login.php

Punto de la consigna	Cómo se cumple	Archivo
B Verificar credenciales con la base	SELECT por email + password_verify()	login.php
B Mensajes claros si son incorrectos	Mensajes de error en rojo	login.php
B Sesiones de PHP	$_SESSION con id, nombre y rol	login.php, includes/funciones.php
B Cerrar sesión	Botón en el menú	cerrar_sesion.php, includes/plantilla.php
C Sección protegida	requerirLogin()	panel.php
C Mostrar datos personales	Ficha con los datos desde la base	panel.php
C Impedir acceso sin sesión	Redirección al login con mensaje	includes/funciones.php
D Acceso exclusivo de administrador	requerirAdmin() en cada página y acción	includes/funciones.php + archivos admin
D Registrar usuarios desde el panel	Formulario de alta con elección de rol	admin_usuarios.php
D Listado de usuarios	Tabla de usuarios activos	admin_usuarios.php
D Buscador por nombre, apellido, DNI o correo	Campo único con LIKE preparado	admin_usuarios.php
D Editar usuarios	Formulario de edición validado	editar_usuario.php
D Archivar sin eliminar	UPDATE de fecha_archivado (sin DELETE)	archivar_usuario.php
D Consultar archivados y reactivar	Listado + botón Reactivar	usuarios_archivados.php, reactivar_usuario.php
E Base de datos con nombre del proyecto	tienda_legos	tienda_legos.sql
E Tabla usuarios con todos los campos pedidos	id, nombre, apellido, dni, email, password, rol, fecha_creacion, fecha_archivado	tienda_legos.sql
E Tipos de datos y restricciones	INT UNSIGNED, VARCHAR, ENUM, DATETIME, NOT	tienda_legos.sql

Punto de la consigna	Cómo se cumple	Archivo
	NULL, PK, UNIQUE	
E DNI y correo no repetidos	UNIQUE KEY en ambos	tienda_legos.sql
Requisitos técnicos	VS Code, XAMPP/Laragon, PHP, MySQL, phpMyAdmin, HTML, CSS, PDO	Todo el proyecto, README.md
No hay pantallas estáticas	Todos los formularios guardan y leen de MySQL	Todo el proyecto
Seguridad (los 7 puntos)	Ver sección 2	includes/funciones.php y demás
Estructura ordenada	Archivos con los nombres de referencia + carpeta includes con 2 archivos de código compartido	Ver README.md
Pruebas obligatorias (1 a 9)	Guía paso a paso	Sección 3 de este documento
Material: carpeta completa	Carpeta tienda_legos	—
Material: archivo SQL	Script de creación	tienda_legos.sql
Material: explicación general	Sección 1	DOCUMENTACION.md
Material: capturas propias	**Previamentes subidas**	—
Material: medidas de seguridad	Sección 2	DOCUMENTACION.md
Material: dificultades	Base de datos	DOCUMENTACION.md
Ejecutable en XAMPP/Laragon con instrucciones	Instalación paso a paso	README.md
Extra: catálogo y página de producto	Array de productos recorrido con foreach	includes/funciones.php, index.php, producto.php
Extra: carrito y finalizar compra	Carrito en la sesión; pedido guardado en pedidos y pedido_items	carrito.php, tienda_legos.sql
Extra: historial de compras	"Mis pedidos" en el panel personal	panel.php